Tehdit İstihbaratında İki Parçalı Ağ Analizi: MITRE ATT&CK Tehdit Grupları ve Teknikleri

Kaan Semih Kurt (2516016008) · Manisa Celal Bayar Üniversitesi, Manisa Teknik Bilimler MYO, Büyük Veri Analistliği · Sosyal Ağ Analizi dönem ödevi · Öğr. Gör. Osman Can Çetlenbik · 2026–2027 Güz · Veri: MITRE ATT&CK Enterprise v20.0

Özet. MITRE ATT&CK Enterprise verisinden 174 tehdit grubu ile 515 teknik/alt-teknik arasında 4.815 “kullanır” bağından oluşan iki parçalı bir ağ kurduk. Açgözlü kapsama analizi, yalnızca **6 tekniğin grupların %90'ını**, 17 tekniğin tamamını en az bir tekniğinden yakalayabildiğini gösterdi (tekniği popülerliğe göre seçmek tamamı için 203 teknik gerektiriyor). Her grubu en az üç tekniğinden yakalama hedefinde %80 kapsama için 16 teknik yetiyor. Newman ağırlıklı grup projeksiyonunda Louvain ve Leiden aynı dört topluluğu buldu (modülerlik 0,092); topluluklar ülkeye değil saldırı tarzına göre ayrışıyor. Aynı derece dizisine sahip 100 rastgele ağla karşılaştırıldığında modülerlik anlamlı biçimde yüksek (z = 29,7), projeksiyondaki yüksek kümelenme ise derece dizisinin kendiliğinden ürettiği bir etki (z = -0,5).

1. Giriş ve araştırma soruları

MITRE ATT&CK, gerçek saldırılarda gözlenen saldırgan davranışlarını taktik (amaç), teknik (yöntem) ve tehdit grubu (aktör) düzeyinde kayıt altına alan açık bir bilgi tabanıdır. Savunma ekipleri her tekniği aynı anda izleyemez; tespit kuralı yazmak, test etmek ve alarm yönetmek zaman ve bütçe ister. Bu nedenle iki soruya ağ analiziyle yanıt aradık:

- **S1.** Savunma ekibi sınırlı bütçeyle hangi teknikleri öncelikle tespit etmeli?
- **S2.** Hangi tehdit grupları benzer davranıyor?

Gruplar ile teknikler doğal olarak iki ayrı düğüm türü oluşturduğu için ağı *iki parçalı (bipartite)* kurduk ve hem bu ağı hem de iki projeksiyonunu (grup–grup, teknik–teknik) inceledik.

2. Veri ve ağın kurulması

Kaynak: `github.com/mitre/cti` deposundaki Enterprise ATT&CK STIX 2.1 paketi, sürüm etiketi `ATT&CK-v20.0` (13 Ekim 2026). Veri `src/fetch_build.py` scriptiyle sabit sürümden indirilir; SHA-256 özeti (`66f3fe3f07ef1a2d…`) `metadata.json`'a yazılır, böylece ham veriden ağa giden her adım tekrarlanabilir. **Lisans:** ATT&CK Kullanım Koşulları araştırma amaçlı kullanım ve yeniden dağıtıma, MITRE telif notu korunarak izin verir. Veride yalnızca kamuya açık tehdit grubu adları bulunur; bireysel kullanıcı verisi yoktur.

Karar	Seçim	Gerekçe
Düğümler	Tehdit grupları (`intrusion-set`) ve teknik/alt-teknikler (`attack-pattern`)	Araştırma sorusu grup ile teknik arasındaki ilişkiyi soruyor.
Kenar	`uses` ilişkisi: “grup X, teknik Y'yi kullanır”	ATT&CK'te gözlenmiş kullanımı doğrudan temsil eder.
Yön / ağırlık	Yönsüz, ağırlıksız	ATT&CK kullanım sıklığı vermez; bilgi “var/yok” düzeyinde.
Alt-teknikler	Ayrı düğüm	Tespit kuralları alt-teknik düzeyinde yazılır (ör. PowerShell ≠ Windows Command Shell). Ana tekniğe toplandığında ağ 174+204 = 378 düğüme düşer ve 500 düğüm koşulunu sağlamaz.
Filtre	İptal edilmiş (revoked) / kullanımdan kalkmış (deprecated) kayıtlar çıkarıldı; hiçbir grupla bağı olmayan 191 teknik ağa alınmadı	Bağı olmayan teknik iki soruya da bilgi taşımaz (sınırlarda tartışıldı).

Projeksiyon ağırlığı	Newman (2001): $w_{ij} = \Sigma_k\ 1/(d_k-1)$	Çok yaygın bir tekniği paylaşmak benzerliğe az, nadir bir tekniği paylaşmak çok katkı verir.

Sonuç ağ: 689 düğüm (174 grup, 515 teknik; bunların 335'i alt-teknik), 4.815 kenar. Grup projeksiyonu 174 düğüm / 11.776 kenar, teknik projeksiyonu 515 düğüm / 45.864 kenar. Kenar listesi (`edges.csv`), düğüm listesi (`nodes.csv`) ve üç GraphML dosyası depoda yayımlandı; her sütunun anlamı `data/DATA_DICTIONARY.md` veri sözlüğündedir. Ağ çok büyük olmadığından örnekleme yapılmadı; tüm ölçüler tam hesaplandı.

3. Yöntem

Temel ölçüler iki parçalı ağ üzerinde hesaplandı (yoğunluk, bileşenler, ortalama en kısa yol, çap, derece benzeşimi). İki parçalı ağda üçgen oluşamayacağı için kümelenme hem Latapy vd. (2008) iki parçalı katsayısıyla hem de projeksiyonlarda ölçüldü. **Derece dağılımı** `powerlaw` paketiyle (Clauset vd., 2009; Alstott vd., 2014) incelendi: kuvvet yasası uydurulup log-normal ve üstel dağılımlarla normalize log-olabilirlik oranı (R, p) ile karşılaştırıldı. **Merkeziyet:** derece, betweenness, closeness, PageRank ve eigenvector; ilk 10 tabloları ve ölçüler arası Spearman korelasyonu. **Topluluk tespiti:** Newman ağırlıklı grup ve teknik projeksiyonlarında Louvain (Blondel vd., 2008) ve Leiden (Traag vd., 2019); her biri 10 farklı tohumla çalıştırıldı, tohumlar arası benzerlik NMI ve ARI ile ölçüldü. **Null model:** iki parçalı derece korumalı kenar takası (Maslov ve Sneppen, 2002 yaklaşımının iki parçalı uyarlaması) ile 100 rastgele ağ üretildi; her biri projekte edilip kümelenme, ortalama yol, yoğunluk ve Louvain modülerliği hesaplandı ve z-skoru verildi. **Kişisel ileri yöntem:** (a) Newman ağırlıklı projeksiyon, (b) Jaccard benzerliğiyle grup kümeleri (k = 5 en yakın komşu Jaccard ağı + Leiden), (c) “en az teknikle en çok grubu kapsama” için açgözlü küme örtüsü (Johnson, 1974; Chvátal, 1979). Bir grup, seçilen tekniklerden en az *k* tanesini kullanıyorsa kapsanmış sayıldı (k = 1, 2, 3). Ayrıca yalnızca kurum ağında tespit edilebilir tekniklerle bir varyant hesaplandı. Bu varyantta Keşif ve Kaynak Geliştirme taktikleri, saldırı öncesinde kurban ağının dışında gerçekleştiği için çıkarıldı. Tüm rastgele adımlar `SEED = 42` ile sabittir; topluluk algoritmaları tekrarlanabilirlik için tamsayı etiketli kopyalar üzerinde çalıştırıldı.

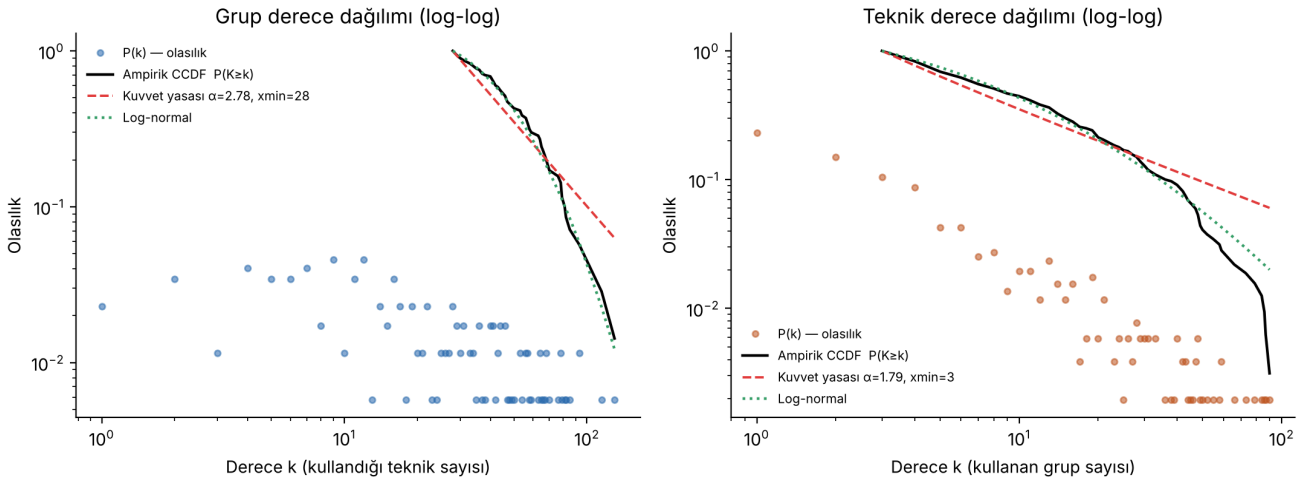
4. Bulgular

4.1 Temel yapı

Ölçü	Değer	Bu ağda ne anlama geliyor?
Düğüm / kenar	689 / 4.815	174 grup + 515 teknik; 4.815 “kullanır” bağı
Yoğunluk (iki parçalı)	0,054	Olası grup–teknik çiftlerinin %5,4'ü gözlenmiş
Bileşen sayısı	1	Kopuk grup yok; her grup en az bir tekniği paylaşıyor
Ort. en kısa yol / çap	3,13 / 7	İki grup tipik olarak tek bir ortak teknikle (2 adım) bağlı
Kümelenme (üçgen) / Latapy	0 / 0,108	İki parçalı ağda üçgen yok; komşu tekniklerin kullanıcıları ~%11 örtüşüyor
Derece benzeşimi	-0,284	Çok belgelenmiş gruplar nadir tekniklere de bağlanıyor
Grup başına teknik (ort./medyan)	27,7 / 19	Grupların çoğu küçük bir teknik alt kümesi kullanıyor
Teknik başına grup (ort./medyan)	9,3 / 4	Ağır kuyruk: medyan 4, en yaygın teknik 90 grup
Grup projeksiyonu: yoğunluk / kümelenme	0,782 / 0,893	Grup çiftlerinin %78'i en az bir tekniği paylaşıyor
Teknik projeksiyonu: yoğunluk / kümelenme	0,347 / 0,611	Tekniklerin üçte biri aynı grupta birlikte görülüyor

Derece benzeşiminin negatif olması (−0,28), nadir tekniklerin büyük ölçüde iyi belgelenmiş gruplarda göründüğünü gösteriyor. Az raporlanmış gruplar ise çoğunlukla herkesin kullandığı tekniklerle ağa bağlanıyor. Projeksiyonlardaki yüksek kümelenme (0,89) ilk bakışta güçlü bir “grup kümelenmesi” gibi görünse de 4.4'te gösterildiği gibi rastgele ağlarda da aynı düzeyde çıkıyor.

4.2 Derece dağılımı



Şekil 1. Grup (solda) ve teknik (sağda) derece dağılımları, log-log. Noktalar P(k), siyah çizgi ampirik CCDF; kırmızı kesikli çizgi kuvvet yasası, yeşil noktalı çizgi log-normal uyumu.

Teknik derecesi ağır kuyruklu. Medyan teknik 4 grupça, T1105 Ingress Tool Transfer ise 90 grupça (%52) kullanılıyor. Kuvvet yasası uyumu $\alpha = 1{,}79$ ($x_{min} = 3$) verse de log-normal dağılım anlamlı biçimde daha iyi ($R = -4{,}20$, $p < 0{,}001$); üstel dağılımla fark anlamlı değil ($p = 0{,}70$). **Grup derecesinde** ($x_{min} = 28$, $\alpha = 2{,}78$) hem log-normal ($p = 0{,}023$) hem üstel ($p = 0{,}001$) kuvvet yasasından daha iyi uyuyor. Dolayısıyla ağı "ölçekten bağımsız" diye nitelemek yanlış olur. Pratik sonuç şu: birkaç "evrensel" teknik çok sayıda grubu kapsıyor ve kapsama analizinin az teknikle yüksek kapsama vermesinin nedeni bu.

4.3 Merkeziyet

#	Derece (teknik)	Grup	Betweenness	PageRank
1	T1105 Ingress Tool Transfer	90	T1588.002 Tool	T1105 Ingress Tool Transfer
2	T1204.002 Malicious File	87	T1059.001 PowerShell	T1204.002 Malicious File
3	T1059.001 PowerShell	86	T1105 Ingress Tool Transfer	T1588.002 Tool
4	T1588.002 Tool	84	T1204.002 Malicious File	T1059.001 PowerShell
5	T1566.001 Spearphishing Attachment	79	T1566.001 Spearphishing Attachment	T1566.001 Spearphishing Attachment
6	T1059.003 Windows Command Shell	73	T1059.003 Windows Command Shell	T1059.003 Windows Command Shell
7	T1036.005 Match Legitimate Resource Name or Location	66	T1036.005 Match Legitimate Resource Name or Location	T1036.005 Match Legitimate Resource Name or Location
8	T1082 System Information Discovery	59	T1071.001 Web Protocols	T1071.001 Web Protocols
9	T1547.001 Registry Run Keys / Startup Folder	59	T1082 System Information Discovery	T1082 System Information Discovery
10	T1071.001 Web Protocols	58	T1078 Valid Accounts	T1547.001 Registry Run Keys / Startup Folder

Tablo 1. İlk 10 teknik: derece, betweenness ve PageRank sıralamaları.

#	Derece (grup)	Teknik	Betweenness	Eigenvector
1	Kimsuky	130	Kimsuky	Kimsuky
2	APT38	115	APT38	APT38
3	APT28	93	APT28	Lazarus Group
4	Lazarus Group	93	Mustang Panda	APT32
5	Mustang Panda	85	APT29	Magic Hound
6	APT41	82	Lazarus Group	Mustang Panda
7	Volt Typhoon	81	Salt Typhoon	OilRig
8	Sandworm Team	79	Volt Typhoon	APT41
9	APT32	78	Scattered Spider	Sandworm Team
10	Magic Hound	78	APT41	MuddyWater

Tablo 2. İlk 10 tehdit grubu.

Merkezi teknik, yaygın teknik demek. Teknik tarafında ölçüler arası Spearman korelasyonları 0,92–0,99, grup tarafında 0,86–0,99; bu ağda ölçüler neredeyse birbirinin yerine geçiyor. **Betweenness'ta T1588.002 Tool birinci:** hazır araç edinme (Mimikatz, Cobalt Strike gibi), birbirine benzemeyen grup ailelerini bağlayan ortak araç zinciridir. Derecesine göre betweenness'ı belirgin yüksek "köprü" teknikler de var: örneğin T1120 Peripheral Device Discovery yalnız 9 grupça kullanılıyor ama betweenness sırası 31. **Grup tarafında en merkezde** Kimsuky, APT38, APT28 ve Lazarus Group var. Bu sıralama "en tehlikeli grup" anlamına gelmez, raporlanma yoğunluğunu yansıtır (bkz. Sınırlar).

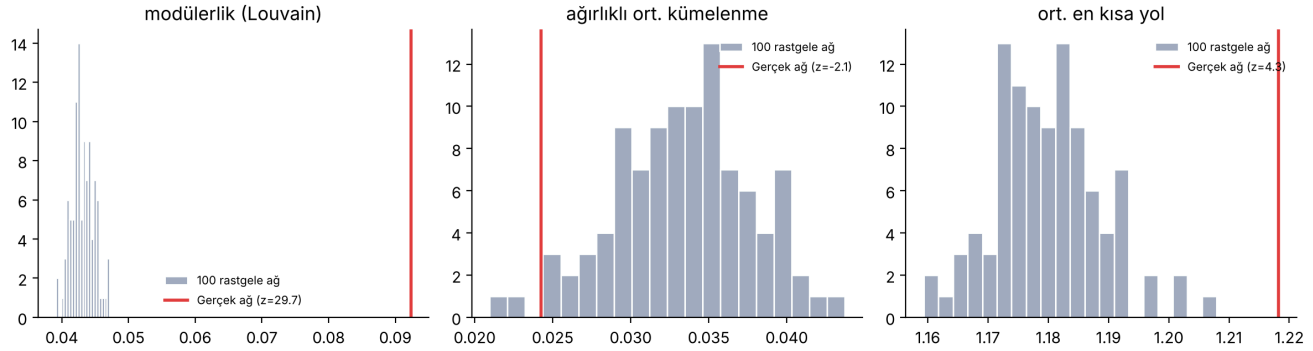
4.4 Topluluklar ve null model

#	Topluluk adı	Grup	Öne çıkan üyeler	Ayırt edici teknikler
0	**Oltalama ve zararlı belgeyle sızanlar**	75	APT32, Gamaredon Group, MuddyWater, FIN7, Leviathan, Earth Lusca	T1189 Drive-by Compromise (lift 1,6); T1059.005 Visual Basic (lift 1,6); T1566.001 Spearphishing Attachment (lift 1,6)
1	**Ağ içi keşif ve yanal hareket ustaları**	56	APT41, Volt Typhoon, Magic Hound, OilRig, Turla, Wizard Spider	T1087.001 Local Account (lift 2,5); T1021.002 SMB/Windows Admin Shares (lift 2,4); T1078.002 Domain Accounts (lift 2,4)
2	**Bulut, Linux ve güvenilen ilişki saldırganları**	28	APT38, APT28, APT29, NIMBUS MANTICORE, Scattered Spider, VOID MANTICORE	T1078.004 Cloud Accounts (lift 4,9); T1059.004 Unix Shell (lift 4,8); T1199 Trusted Relationship (lift 4,4)
3	**Sosyal mühendislik ve kimlik bilgisi avcıları**	15	Kimsuky, Lazarus Group, Mustang Panda, Sandworm Team, HEXANE, APT42	T1594 Search Victim-Owned Websites (lift 9,7); T1589.002 Email Addresses (lift 5,8); T1539 Steal Web Session Cookie (lift 5,8)

Tablo 3. Newman ağırlıklı grup projeksiyonundaki Leiden toplulukları. Lift = topluluk içi kullanım oranı / genel kullanım oranı.

İki algoritma aynı sonucu verdi. Louvain ve Leiden'in en yüksek modülerlikli çözümleri birebir aynı: 4 topluluk, modülerlik 0,092 (NMI = 1,00, ARI = 1,00). **Kararlılık orta-iyi:** 10 tohumda Leiden için ortalama NMI 0,69, ARI 0,74; topluluk sayısı 3–4. Çekirdek yapı kararlı, sınırdaki bazı gruplar topluluk değiştiriyor. Teknik projeksiyonunda 5 topluluk bulundu (modülerlik 0,110, Louvain–Leiden NMI 0,85). **Adlandırma** ayırt edici tekniklere göre yapıldı. Önemli bulgu, toplulukların ülkeye değil saldırı tarzına göre ayrışması: örneğin "oltalama" topluluğunda Çin, Rusya ve İran bağlantılı gruplarla finansal motivasyonlu gruplar birlikte yer alıyor.

Ölçü (grup projeksiyonu)	Gerçek	100 rastgele ağ (ort. ± std)	z	p
kümelenme (transitivity)	0,8934	0,8953 ± 0,0037	**-0,5**	0,337
ağırlıklı ort. kümelenme	0,0243	0,0334 ± 0,0044	**-2,1**	0,030
ort. en kısa yol	1,2183	1,1799 ± 0,0090	**4,3**	0,010
yoğunluk	0,7824	0,8196 ± 0,0091	**-4,1**	0,010
modülerlik (Louvain)	0,0923	0,0431 ± 0,0017	**29,7**	0,010



Tablo 4 ve Şekil 2. Null model: iki parçalı derece korumalı kenar takasıyla üretilmiş 100 rastgele ağ.

Topluluk yapısı rastlantı değil. Modülerlik rastgele ağların iki katından fazla (z = 29,7); gruplar teknikleri belirli "aileler" hâlinde paylaşıyor. **Kümelenme ise rastlantı.** Projeksiyonun kümelenmesi rastgele ağlarla aynı (z = -0,5); yüksek değer yalnızca derece dizisinden kaynaklanıyor. Null model olmasaydı "gruplar arasında güçlü kümelenme var" diye yanlış bir iddia kurardık. **Gerçek ağ rastgeleden daha seçici:** ortalama yol daha uzun (z = 4,3), yoğunluk daha düşük (z = -4,1), ağırlıklı kümelenme daha düşük (z = -2,1).

4.5 Kişisel ileri yöntem

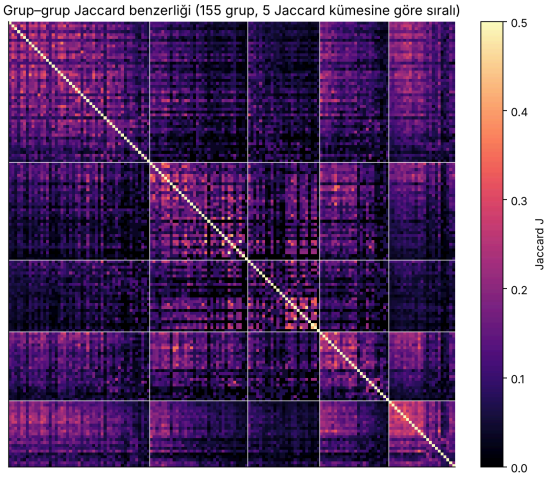
(a) Newman projeksiyonu. Küçük örnek: t1'i A, B, C kullansın; t2'yi yalnız A ve B, t3'ü yalnız B ve C. t1 her çifte 1/(3−1) = 0,5, t2 ve t3 ise 1/(2−1) = 1 katkı verir. Sonuç: A–B = 1,5, B–C = 1,5, A–C = 0,5. A ile C'nin tek ortak noktası herkesin kullandığı t1 olduğu için bağları zayıf kalır. Gerçek ağda ham ortak teknik sayısı ile Newman ağırlığının sıralaması benzer (Spearman 0,92), ancak en güçlü 10 bağın yalnızca 3'ü iki listede ortak. Ham sayı en çok tekniği belgelenmiş grupları öne çıkarıyor: APT38–Kimsuky (60 ortak), Lazarus Group–Kimsuky (49 ortak), Kimsuky–Mustang Panda (48 ortak). Newman ise nadir teknik paylaşanları öne çıkarıyor: LAPSUS$–Scattered Spider (5,65; 21 ortak), Kimsuky–Mustang Panda (5,10; 48 ortak), APT38–Kimsuky (4,67; 60 ortak), Scattered Spider–Storm-0501 (4,56; 17 ortak). En güçlü Newman bağı olan LAPSUS$ ile Scattered Spider, sosyal mühendislik ve kimlik bilgisiyle ilerleyen iki gasp grubu; bu benzerlik ham sayıyla görünmüyor.

(b) Jaccard benzerliğiyle grup kümeleri. En az 5 tekniği olan 155 grup için $J(A,B) = |T_A \cap T_B| / |T_A \cup T_B|$ hesaplandı (19 grup çok az veri nedeniyle dışarıda). Ortalama çift benzerliği yalnızca 0,095. Bu yüzden klasik hiyerarşik kümeleme tek dev küme üretti (siluet 0,05). Her grubu en benzer 5 grubuna bağlayan k-NN Jaccard ağında Leiden **5 küme** buldu (modülerlik 0,53, tohumlar arası NMI 0,79). Siluet değeri (0,023) düşük; kümeler keskin sınırlı değil, "yumuşak aileler". En benzer büyük çiftler: Patchwork–Sidewinder (J = 0,39, 20 ortak), APT-C-36–TA2541 (J = 0,38, 18 ortak), Threat Group-3390–menuPass (J = 0,37, 28 ortak), MuddyWater–Earth Lusca (J = 0,35, 29 ortak), Tropic Trooper–Sidewinder (J = 0,35, 18 ortak).

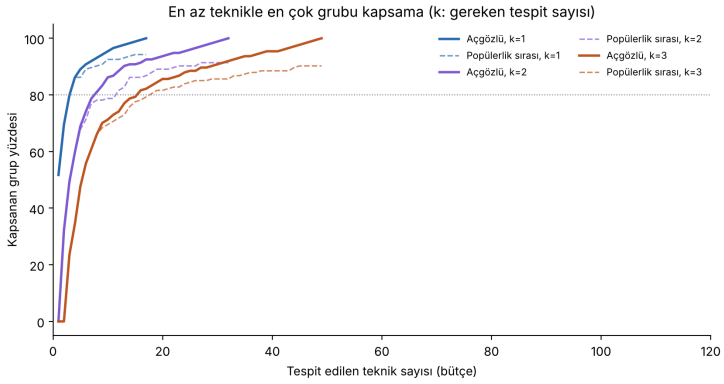
#	Jaccard kümesi	Grup	Öne çıkan üyeler	Ayırt edici teknikler
0	**Ağ içinde el ile ilerleyenler (casusluk + fidye)**	49	APT28, APT41, Volt Typhoon, APT29, Wizard Spider, Chimera	T1021.001 Remote Desktop Protocol; T1018 Remote System Discovery
1	**Bağlantılı oltalama kampanyaları**	34	APT-C-36, TA505, Moonstone Sleet, LuminousMoth, TA2541, WIRTE	T1608.001 Upload Malware; T1204.001 Malicious Link
2	**Zararlı ek ve hazır araç kullananlar**	25	Gorgon Group, Tonto Team, BackdoorDiplomacy, Andariel, Moses Staff, PLATINUM	T1204.002 Malicious File; T1566.001 Spearphishing Attachment
3	**Drive-by ve şifreli C2 kullanan casusluk grupları**	24	Patchwork, RedCurl, BRONZE BUTLER, Tropic Trooper, APT33, Sidewinder	T1573.001 Symmetric Cryptography; T1555.003 Credentials from Web Browsers
4	**Geniş repertuvarlı, en çok belgelenen gruplar**	23	Kimsuky, APT38, Lazarus Group, Mustang Panda, Sandworm Team, APT32	T1485 Data Destruction; T1589 Gather Victim Identity Information

Tablo 5. k-NN Jaccard ağının Leiden kümeleri.

Newman topluluklarıyla uyum orta düzeyde (NMI = 0,29). Newman nadir ortak teknikleri ödüllendiriyor, Jaccard grup büyüklüğünü normalize ediyor; iki yöntem benzerliğin farklı yüzlerini gösteriyor. “Geniş repertuvarlı” küme kısmen bir boyut etkisi, çünkü çok tekniği belgelenmiş gruplar birbirine daha çok benziyor.



Şekil 3. Grup–grup Jaccard matrisi, kümelere göre sıralı.



Şekil 4. Açgözlü kapsama eğrileri (düz) ve popülerlik sırası (kesikli); k = gereken tespit sayısı.

(c) Açgözlü kapsama. k = 1 için 4 teknik grupların %86'sını, 6 teknik %90'ını, 17 teknik tamamını kapsıyor. Popülerlik sırasıyla tamamı için 203 teknik gerekiyor; çünkü az tekniği belgelenmiş gruplar ancak nadir tekniklerle yakalanabiliyor ve açgözlü seçim bu tamamlayıcı teknikleri bilinçli olarak seçiyor. Tek bir tespit kolayca atlatılabileceğinden daha gerçekçi hedef k = 3: %80 için 16, %90 için 29, tamamı için 49 teknik (popülerlik: 18 / 45 / 370).

#	Teknik (k = 1)	Taktik	Grup	Yeni	Küm. %
1	T1105 Ingress Tool Transfer	command-and-control	90	90	51,7
2	T1204.002 Malicious File	execution	87	31	69,5
3	T1588.002 Tool	resource-development	84	18	79,9
4	T1059.001 PowerShell	execution	86	11	86,2
5	T1059.003 Windows Command Shell	execution	73	5	89,1
6	T1071.001 Web Protocols	command-and-control	58	3	90,8
7	T1083 File and Directory Discovery	discovery	52	2	92,0
8	T1027.013 Encrypted/Encoded File	stealth	40	2	93,1
9	T1583.006 Web Services	resource-development	29	2	94,3
10	T1657 Financial Theft	impact	19	2	95,4
11	T1564.005 Hidden File System	stealth	2	2	96,6
12	T1078 Valid Accounts	stealth, persistence, privilege-escalation, initial-access	49	1	97,1

Tablo 6. k = 1 açgözlü öncelik listesi (ilk 12). “Yeni” = o adımda ilk kez kapsanan grup sayısı.

#	Teknik — yalnızca tespit edilebilir, k = 3	Taktik	Grup	Küm. %
1	T1105 Ingress Tool Transfer	command-and-control	90	1,1
2	T1204.002 Malicious File	execution	87	1,1
3	T1059.001 PowerShell	execution	86	24,7
4	T1059.003 Windows Command Shell	execution	73	38,5
5	T1566.001 Spearphishing Attachment	initial-access	79	50,0
6	T1036.005 Match Legitimate Resource Name or Location	stealth	66	56,3
7	T1078 Valid Accounts	stealth, persistence, privilege-escalation, initial-access	49	62,1
8	T1082 System Information Discovery	discovery	59	67,2
9	T1190 Exploit Public-Facing Application	initial-access	47	70,7
10	T1071.001 Web Protocols	command-and-control	58	73,6

Tablo 7. Uygulanabilir öncelik listesi: Keşif ve Kaynak Geliştirme dışındaki 435 teknikten seçilen ilk 10 (k = 3). İlk 10 teknikle grupların %73,6'i, ilk 20 teknikle %84,5'i en az üç tekniğinden yakalanabiliyor.

5. Tartışma: soruların cevabı

S1. Hangi teknikler önce tespit edilmeli? Sınırlı bütçeli bir ekip Tablo 7'deki listeyle başlamalı: PowerShell, Ingress Tool Transfer, kötü amaçlı dosya çalıştırma, oltalama eki, Windows komut satırı, meşru ad/konum taklidi ve geçerli hesap kullanımı gibi. Bu tekniklerin ilk 10'u grupların %74'ini en az üç farklı noktadan görünür kılıyor. Bütçe arttıkça popüler olanı değil, *henüz kapsanmayan grupları* yakalayan tamamlayıcı tekniği eklemek gerekir; açgözlü seçim popülerlik sırasına göre çok daha az teknikle tam kapsama sağlıyor.

S2. Hangi gruplar benzer davranıyor? Gruplar dört davranış ailesine ayrışıyor: oltalama/zararlı belge, ağ içi keşif ve yanal hareket, bulut-Linux-güvenilen ilişki, sosyal

mühendislik ve kimlik bilgisi toplama. Bu aileler ülke atıflarını kesiyor; savunma açısından “kim saldırıyor” sorusundan çok “nasıl saldırıyor” sorusu belirleyici. Daha ince düzeyde Jaccard kümeleri dikkat çekici bir sonuç veriyor: casusluk grupları (APT28, APT29, APT41, Volt Typhoon) ile fidye yazılımı grupları (Wizard Spider, Medusa Group) aynı kümede. Hedefleri farklı olsa da ağ içinde aynı teknikleri kullanıyorlar (RDP, SMB/Windows yönetici paylaşımları, uzak sistem keşfi); bu teknikleri izleyen bir savunma iki tehdide birden hazır olur. LAPSUS$–Scattered Spider ve Patchwork–Sidewinder gibi çiftler, birinden gelen tehdit istihbaratının diğerine karşı da kullanılabileceğini gösteriyor.

6. Sınırlar

- **Raporlama yanlılığı:** ATT&CK gözlenen değil *raporlanan* davranışı içerir. Çok raporlanan gruplar (Kimsuky, APT38, Lazarus) daha fazla teknikle görünür; merkeziyet ve “geniş repertuvar” kümesi bu etkiyi taşır.
- **İkili ve zamansız kenarlar:** kullanım sıklığı, tarihi ve güncelliği yok; 2012'de görülen bir teknik ile bugün kullanılan aynı ağırlıkta.
- **Kapsam dışı ilişkiler:** kampanyalar (campaign) ve yazılımlar (malware/tool) üzerinden dolaylı teknikler ile hiçbir grupla bağı olmayan 191 teknik dahil edilmedi. Bu tekniklerin önemsiz olduğu anlamına gelmez.
- **Alt-teknik ve ana teknik ayrı düğüm:** T1059 ile T1059.001 farklı düğüm olduğu için bazı benzerlikler bölünmüş görünebilir.
- **Kapsama ≠ tespit kalitesi:** bir tekniği izlemek her kullanımını yakalamak demek değildir; yanlış alarm oranı ve tespit maliyeti modele girmedi. Açgözlü algoritma en iyi çözümün en fazla ln(n)+1 katı garanti verir, optimumu değil.
- **Topluluk kararlılığı:** modülerlik düşük (0,09) ve tohumlar arası NMI ~0,7; topluluk sınırları kesin değil, çekirdek yapı kararlı.
- **Nedensellik:** bulgular ilişki gösterir; aynı tekniği kullanmak grupların iş birliği yaptığı ya da aynı ülkeye bağlı olduğu anlamına gelmez, ağ verisinden nedensellik çıkarılamaz. Ülke atıfları MITRE açıklamalarına dayanır.

Kaynakça

1. MITRE Corporation (2026). *ATT&CK Enterprise v20.0*, STIX 2.1 veri paketi. github.com/mitre/cti. © The MITRE Corporation, izinle yeniden dağıtılmıştır.
2. Newman, M. E. J. (2001). Scientific collaboration networks. II. Shortest paths, weighted networks, and centrality. *Physical Review E*, 64, 016132.
3. Blondel, V. D., Guillaume, J.-L., Lambiotte, R., Lefebvre, E. (2008). Fast unfolding of communities in large networks. *J. Stat. Mech.*, P10008.
4. Traag, V. A., Waltman, L., van Eck, N. J. (2019). From Louvain to Leiden: guaranteeing well-connected communities. *Scientific Reports*, 9, 5233.
5. Clauset, A., Shalizi, C. R., Newman, M. E. J. (2009). Power-law distributions in empirical data. *SIAM Review*, 51(4), 661–703.
6. Alstott, J., Bullmore, E., Plenz, D. (2014). powerlaw: a Python package for analysis of heavy-tailed distributions. *PLoS ONE*, 9(1), e85777.
7. Latapy, M., Magnien, C., Del Vecchio, N. (2008). Basic notions for the analysis of large two-mode networks. *Social Networks*, 30(1), 31–48.
8. Maslov, S., Sneppen, K. (2002). Specificity and stability in topology of protein networks. *Science*, 296, 910–913.
9. Johnson, D. S. (1974). Approximation algorithms for combinatorial problems. *J. Computer and System Sciences*, 9, 256–278; Chvátal, V. (1979). A greedy heuristic for the set-covering problem. *Math. of Operations Research*, 4(3), 233–235.
10. Hagberg, A., Schult, D., Swart, P. (2008). Exploring network structure, dynamics, and function using NetworkX. *Proc. SciPy*, 11–15.
11. Vinh, N. X., Epps, J., Bailey, J. (2010). Information theoretic measures for clusterings comparison. *JMLR*, 11, 2837–2854; Hubert, L., Arabie, P. (1985). Comparing partitions. *J. Classification*, 2, 193–218.

Kod ve veri: github.com/kaansemihkurt/mitre-attack-network-analysis · **Etkileşimli ağ:** kaansemihkurt.vercel.app/projeler/mitre-attack · **Yapay zekâ beyanı:** Veri toplama scripti, analiz defteri, görselleştirmeler, bu rapor ve sunum yapay zekâ asistanı Claude (Anthropic) ile birlikte hazırlanmıştır. Öğrenci tüm adımları inceleyip çalıştırmış ve sunumda açıklamaktan sorumludur; ayrıntılar README'dedir.